

-

File No.: EXP202311252

RESOLUTION OF FILE OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On June 27, 2023, a complaint was filed with registration number REGAGE23e00042081608 before the Spanish Agency for Data Protection by A.A.A. (hereinafter, the complainant) against XFERA MÓVILES, S.A.U. with NIF A82528548 (hereinafter, XFERA). The reasons for the complaint are as follows:

The complainant states that on May 19, 2023, after receiving a call identifying itself as Yoigo (the commercial brand name of XFERA) from the number ***PHONE.1, they contracted a reduction in their bill and acquired a mobile device at zero cost. They indicate that the contract was made via a call from the phone number ***PHONE.1 and through the WhatsApp application via conversation with the number ***PHONE.2.

The complainant also indicates that they were informed, once the upgrade was contracted, that there had been an error in the shipment, but that, nevertheless, they should pick up the device at the post office so that a courier could go to collect it at their home and that the correct device would be sent later.

Once the device was collected from their home, the complainant checks on the XFERA website that it shows they have actually acquired the Xiaomi device collected at their home, and that they must pay for it in 24 installments. They believe that this contract was made without their consent, and therefore they are claiming against XFERA for the improper contracting.

Along with their complaint, they provide a conversation via WhatsApp held with the indicated phone numbers, which they believed were XFERA's, as well as the call history received from those numbers and the tariff contracted with XFERA, without their consent.

Relevant documentation provided by the complainant:

- Conversation via WhatsApp supposedly held with XFERA with the number ***PHONE.2 between May 23, 26, 30, and 31, 2023,
- Complaint number filed with YOIGO, dated June 9, 2023,
- Call history received from number ***PHONE.1 between May 19, 2023, and June 12, 2023, supposedly from Yoigo, including the call from May 19, 2023, two calls from May 23, 2023, and three calls from May 26, 2023.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

-

Tariff contracted without their consent, as indicated.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the aforementioned complaint was forwarded to XFERA for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on August 22, 2023, as stated in the acknowledgment of receipt in the file.

On September 22, 2023, XFERA responded to the transfer of the complaint, indicating that the line ***PHONE.1 does not correspond to any of XFERA's loyalty or customer service services, but rather belongs to a private customer, who is also a customer of XFERA. According to the account of the interested party, communication continues via WhatsApp, but in the original XFERA WhatsApp

channel, it is the customers who must proactively initiate the conversation.

They indicate that the interested party provides a WhatsApp conversation with the alleged sales representative dated May 23, 2023, during which false information about an offer is provided, and to gain the interested party's trust, a Yoigo invoice is provided.

After conducting checks for this case, it is verified that the interested party received several calls on applications like Skype that coincided temporally with the events. No sales representative or service from XFERA uses services like Skype or WhatsApp calls to contact customers.

The times of the WhatsApp messages received and provided in this complaint are later or simultaneous to these calls, and XFERA cannot certify the origin as they are Skype-type calls.

From the interested party's traffic and the logs from the interested party's customer area, it is evident that a password change was made on the same day, May 23, from a suspicious IP address (different from the rest of the accesses to the interested party's private area) prior to the time when their invoice was sent.

Through the private area, customers can download invoices and (...). In the extraction of the interested party's traffic, a Skype call is noted at 20:51 and at 21:17 (...). The invoice is provided at 21:26.

These facts suggest that the interested party provided the code to reset the password for the private area to the individuals who contacted them, despite the SMS we sent indicating that this code should not be provided to anyone.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/7

XFERA sends the mobile terminals to the nearest post office to the interested party's residence, so that they can provide the necessary documentation to carry out the financing and thus sign the contract for the delivered terminal.

XFERA concludes that there is a high probability that the interested party has been a victim of vishing, which subsequently leads to a contract being signed in the name of the interested party, with the impersonators providing all the required information for this. Neither is the shipping code for tracking the shipment correct, nor is the name by which they are called. In the WhatsApp conversation, the criminals even convince the interested party that the signed contract is not valid, and the client signs it under that belief and hands over the terminal.

THIRD: On September 26, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted was admitted for processing.

FOURTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

The contracting of the Xiaomi terminal took place on 05/23/23 as a result of a phone call from the same phone number on 05/19/2023 and through reception via the WhatsApp application from the numbers ***PHONE.2 and ***PHONE.1.

During the current preliminary actions, XFERA MÓVILES, S.A. with NIF A82528548 and registered office at AVENIDA DE BRUSELAS, N.º 38 - 28108 ALCOBENDAS (MADRID) has been investigated, for which the ownership of the phone lines from which the calls are received and messages are exchanged via WhatsApp is first verified.

XFERA is not the owner of the 2 phone lines involved; rather, they belong to private individuals, B.B.B. and C.C.C., of nationality (...), who have contracted both lines with XFERA on a prepaid basis, using their passport number for this purpose. Both lines were deactivated shortly after the terminal was contracted by the interested parties.

After XFERA sent the Xiaomi terminal to the client, the impersonators inform him that an incorrect model has been sent, but that, nevertheless, he should pick it up from the post office and a courier will come to collect the terminal from his home, and they will send him the correct terminal later. Once the

terminal is collected and the contract is signed, the claimant verifies on the Yoigo website that it shows he has acquired a Xiaomi terminal with the associated conditions; when calling the respective phone numbers ***PHONE.2 and ***PHONE.1, he finds that those numbers no longer exist.

XFERA concludes that this is a case of "vishing," a social engineering scam by phone, through which the customer's data is obtained, first by impersonating the identity.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/7

of XFERA through calls made in its name, to obtain the appropriate information from the client and to impersonate them in order to contract services in their place, once the trust of the client has been gained.

For its part, the claimant categorically denies having requested a password change in their XFERA client area on 23/05/2023, or on any other day, nor having received on that date any SMS from XFERA with a valid code for 24 hours, as well as having provided their OTP for the password change. They also deny having used Skype in this action and even provide a copy of the last communications carried out via Skype.

Therefore, the investigation aims to verify whether the measures applied by XFERA have been adequate to ensure the security in the processing of the personal data of the party being claimed in this contract.

XFERA generally explains the security policy it applies:

1) The security policy for accessing the private area and for changing the password requires a combination of (...).

In case of forgetting the password, clients have the option "Can't you log in?" which opens a dialog box where it is required to enter (...); otherwise, it would result in an error. In the case of a Yoigo client, it sends (...).

2) The layered security policy requires for the renewal process and signing of the contract: (...), and as a reinforced measure, to provide a (...). In this case, for devices that include financing, the device is sent (...).

XFERA states that the process and contracting of a new device can only be initiated by the client themselves, and not by XFERA. It provides the logs of calls and SMS received by the claimant, related to the screenshots of the calls and WhatsApp messages provided by the claimant, which explain (in CEST time) the successive chronology of events.

XFERA provides evidence of the sending of (...), to the claimant's phone line and that they signed a contract for the new rate and a Xiaomi device, even providing a copy of their ID at the post office.

XFERA states that the two phone calls on 23/5/23, lasting about 20 minutes and about 5 minutes, occur in parallel with a WhatsApp conversation of the interested party with the impersonator; during these calls, the impersonator would manage, through deception of the client, the (...), the password change sent to the number of the claimant, since it is recorded in XFERA's systems that the password change was made by entering the correct (...).

XFERA explains that, with this password, it obtains the last invoice of the claimant, which it forwards via WhatsApp, to convince them that the transaction is indeed taking place with XFERA, thus knowing exactly what services they had contracted. Finally, the impersonator called the claimant to inform them that there was an error with the device sent for them to pick up at the post office, where they signed the contract along with their ID, a requirement without which it would be impossible to acquire an item on credit with XFERA.

XFERA concludes that the impersonator obtains the device at the claimant's home and from their own hand, also charging them for its cost: thus closing the circle of vishing, making them believe that the correct device was on its way.

The report of the preliminary actions of the AEPD concludes that the evidence collected in the investigation is basically consistent with the statements of XFERA and that the conduct of the affected party may have induced the investigated facts.

LEGAL GROUNDS

I

Competence

In accordance with the functions conferred on each supervisory authority by Article 57.1 a), f) and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve these investigative actions.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Security of processing

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/7

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism approved pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.

III

Integrity and confidentiality

Letter f) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

IV

Conclusion

Therefore, based on the information provided in the previous paragraphs, no evidence has been found

to substantiate the existence of an infringement by XFERA within the jurisdiction of the Spanish Data Protection Agency.

The complainant has acknowledged signing the telephone line contract, even providing a copy of their ID for this purpose. They also acknowledge having handed over the contracted device to the alleged impersonators, believing that they were XFERA personnel and that the signed contract was not valid at that time.

The evidence and testimonies do not conclusively clarify how the alleged impersonators obtained the necessary credentials to access the complainant's personal data or their account in the User Area of the XFERA website.

All of this is without prejudice to any subsequent actions that this Agency may carry out, exercising the investigative and corrective powers it holds.

Thus, as it has not been possible to attribute responsibility to XFERA for the facts subject to the complaint, the Presidency of the Spanish Data Protection Agency RESOLVES:

FIRST: TO ARCHIVE the present proceedings.

SECOND: TO NOTIFY this resolution to XFERA MÓVILES, S.A.U. and to the complainant.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Presidency of the Spanish Data Protection Agency within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-301023

Lorenzo Cotino Hueso

President of the Spanish Data Protection Agency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es